

making parameters related to the data that the entity produces or manages. Additionally, data governance involves the process for setting and enforcing the business and IT priorities for managing data.¹⁵ The data management process involves the development and execution of policies, standards, and procedures to acquire, validate, store, protect, and process data. Effective data management ensures that the required data are accessible, reliable, and timely to meet user needs. When data are no longer used, management should have a process for the data's removal or destruction and validate the effectiveness of that process.

In larger or more complex entities, data governance and data management are formally managed with defined responsibilities and functions. In smaller or less complex entities, these functions may be included in the responsibilities of a business line manager. Regardless of the entity's size or complexity, business line management, which generally is the most knowledgeable about the entity's data usage, should be consulted to assist in data classification, the development of recovery standards, and control validation by personnel responsible for these activities. Management should define responsibilities and processes for governing data, including the identification, management, and oversight of any metadata. Someone may be able to infer sensitive information from the metadata that could lead to misuse of the information. For example, third-party service providers could sell the metadata, providing an unauthorized individual with information about the entity's customers or business strategies. This could increase legal and reputation risks because the metadata could be used to compromise (e.g., through social engineering) the entity or its customers.

Effective data management continuously evolves as the entity grows or transforms to meet business objectives. Management should promote a culture that takes a data-centric approach, including for AIO functions.

III.A.1 Data Identification and Classification

Data identification and data classification are important components of data management. To effectively manage data, it is important to identify what data the entity has, particularly to identify sensitive customer and entity information. The data identification process includes structured data, managed by a system of record, as well as unstructured data (e.g., physical loan files, emails, documents, images, presentations, or free-form text comment fields in applications) created or processed by end users. There are inventory tools available to assist management with the data identification process. Once the data is accurately identified, it should be appropriately classified.

Data classification is the process of categorizing data based on the expected damage to operations following loss or compromise of the identified information. Classification is based on its level of confidentiality (i.e., sensitivity), integrity, and availability, as well as the value and criticality to the entity. Management should identify and understand the nature of the entity's data to classify it effectively, including the following:

¹⁵ Refer to the U.S. Department of the Treasury's [Data Governance Board Charter](#).

- Sensitivity, criticality, and importance of the data for the entity, its business units, or its customers on a day-to-day basis.
- Frequency, recurrence, and use of data by the entity and its business lines.
- Format in which data are maintained (e.g., database, online files, or paper copies).

Management should use the results of the data classification process for implementing controls to safeguard data, whether in physical (e.g., paper and storage media) or digital form. Management should understand where data reside and maintain the effectiveness of controls over those data, including controls over databases. Management should regularly update the information and technology asset inventory (described in the [“IT Asset Management”](#) section of this booklet) for new assets (e.g., data, hardware, systems and software, and databases) regardless of whether the asset and its data are maintained in-house or by a third-party service provider. For more information, refer to the *IT Handbook’s* [“Information Security”](#) booklet.

III.A.2 Database Management

When evaluating AIO, it is important to evaluate database management. Databases are used to store data so that they can be organized, easily accessed, effectively managed, and readily updated. Often, an entity’s data are stored in databases and accessed or used by software. Databases can exist on mainframes, within internal networks, in a cloud environment, and on standalone computers.

Databases typically contain critical and sensitive data, including customer account data. Therefore, databases pose unique risks (e.g., data corruption, data misuse, data errors, or unauthorized changes). For that reason, securely designing, building, and operating databases are important to protecting the data itself. Management should implement a process to adequately secure and oversee the entity’s databases to minimize the potential for unintentional or unauthorized modification, destruction, or disclosure of sensitive customer or entity information.

As part of understanding where data reside, management should ascertain the effectiveness of database controls, and assign appropriate staff to update the data and technology inventories. Management should determine whether databases are appropriately located and structured, have sufficient capacity, and are resilient. Management should regularly monitor for new databases or significant changes (including data loss) to existing database(s) and report on misconfigured databases or those that are out of compliance with the entity’s configuration standards.

Databases are also an important building block used to construct information for use by business lines, customers, third-party service providers, and partners (e.g., joint ventures). It is important to understand how databases interconnect throughout the entity when developing an architectural design and selecting appropriate infrastructure.

In addition to databases, there are other methods (e.g., data warehouse, database server, tape, and paper) and formats (e.g., structured data and unstructured data) for storing data when considering database management control implementation. Regardless of how the data are stored, the focus should be on identifying, managing, and securing the data as well as identifying business uses for the data and providing access to authorized lines of business.

Responsibilities for database management controls typically are managed by a DBA; however, in smaller or less complex entities, these responsibilities may be assigned to other personnel. A DBA is typically responsible for database configuration, including security configuration, access controls, and maintenance, as well as training employees on databases. Additionally, this individual monitors the databases and maintains awareness of normal operations. A DBA should work with the information security officer to strengthen database security.

A DBA should monitor for anomalous database activities, which could indicate errors or fraud. For example, delays in response time for user queries may indicate the presence of malware or corrupted data. In preparation for such a scenario, the DBA should be familiar with procedures to protect sensitive information, restore normal operations, and notify the information security officer. As DBAs have highly privileged access to databases, use of accounts belonging to DBAs should be limited and independently monitored.

III.A.2(a) *Database Security*

Databases often store sensitive information; therefore, they are frequent targets of malicious activity by internal and external sources. As part of database management activities, management should implement effective database security controls. Examples of database security controls include the following:

- Change passwords for default user accounts and, subsequently, disable or delete those accounts when possible.
- Track and monitor activity for default accounts that cannot be disabled or deleted.¹⁶
- Restrict account access (e.g., to view or modify data, to modify the database or data structure, and to change access rights) and limit privileges and permissions to only those necessary to carry out job responsibilities and automated functions.
- Implement password management tools or activities (e.g., password changes after a determined time frame, vaulting of system-level passwords, and use of password complexity rules).
- Employ an appropriate level of encryption on data in transit and data at rest based on the type and criticality of the information according to the entity's data classification policy.
- Configure and review audit logs (e.g., configuration settings, access control, and log review processes).
- Regularly monitor database activity logs to track account access and activity, including activity that modifies sensitive information and alters the database security parameters or structure (e.g., modifying or deleting database tables or connections).
- Independently monitor DBA and privileged account activities (e.g., use of or changes to system privileges).
- Classify data maintained within the database.

¹⁶ Default accounts often come with the hardware, software, databases, or operating systems. While it is a good practice to disable or delete these accounts, at times system-level default accounts cannot be deleted without affecting the system functionality. In such cases, default passwords on the account should be changed and any activity performed by those accounts monitored.

- Restrict and monitor data extraction (e.g., limiting and monitoring data queries, user abilities, and the use of standardized business intelligence tools¹⁷ to query databases to provide standardized reporting).
- Implement and adhere to patch management processes to maintain a current and secure database and underlying operating system (OS).
- Implement OS controls (e.g., configuration settings and access control).
- Monitor OS-level privileged account activities.
- Manage application-level access (e.g., access by and through applications).

The DBA may use automated tools to help implement controls and monitor the database environment. These tools include database discovery, security scanning, configuration lockdown, automated remediation, and security reporting. For more information, refer to the *IT Handbook's* "[Information Security](#)" booklet.

III.A.3 Non-Production Environments

Entities often have environments beyond the production environment. This allows management to make changes and perform testing in a way that does not impact the entity's production environment. For example, entities that develop their own software often have multiple environments to support their development processes. These non-production environments, commonly used for development, testing (either for testing changes or exploring the feasibility of potential new technologies, products, and services), or quality assurance, provide alternate information processing environments; allowing an entity to develop and test system changes without impacting production. While production environments pose significant risks to the entity and its customer information, non-production environments are not without risks. These risks include:

- **Privacy and misuse of data.** Entities sometimes copy production data into non-production environments, potentially allowing individuals to access information beyond what is needed for their job description.
- **Security tradeoffs.** To facilitate rapid changes or for development and testing of functionality, management may disable or omit security.
- **Data corruption.** Stale or incorrect data may inadvertently corrupt production data if non-production data are not appropriately segregated from production data.
- **Transition to production.** Failure to enable production levels of security may introduce vulnerabilities into the production environment.
- **Secondary use.** At times, non-production environments or data may be used for other than their intended purposes (e.g., training), which could expose sensitive data unnecessarily. Additionally, data used may not be appropriately secured.
- **Data breach.** If non-production environments are not properly secured, malicious actors may gain access and use that access as a conduit into production environments. Additionally,

¹⁷ Business intelligence tools can be used to help management gather and analyze its data (e.g., transactions that match fraudulent activity patterns) and can expand the entity's attack surface because of their access to an entity's databases.

malicious actors may be able to access sensitive data contained within non-production environments.

Management should consider design, placement, and effective security controls for non-production environments. Non-production environments should be independent of production environments to maintain data integrity and resilience. Management should use simulated synthetic data in non-production environments when possible. When production data must be used for testing, it should be masked, or sanitized whenever feasible. In cases where masking data is not feasible, management should require approval by the appropriate level and implement controls similar to those used in production environments. Controls could include IAM, password controls, and logging and monitoring of activity within non-production environments. For more information, refer to the *IT Handbook's* "[Information Security](#)" booklet.

III.A.4 Data Analytics

Data analytics is the process of evaluating and organizing data sets to draw conclusions, make predictions, and reveal trends. The results of data analytics may be used to improve decision-making, optimize processes, and increase efficiency. Data analytics can help management discover hidden patterns, correlations, security threats, trends, customer preferences, and other useful business information. Management should consider the uses and risks of data analytics. While management may use data analytics to make business decisions (e.g., introducing a new product or analyzing security logs), data analytics reports could expose sensitive data. Therefore, management should limit access to analytics tools and related outputs and incorporate confidentiality, integrity, and availability when designing or selecting analytics tools. Management also should inventory the data sources, assess the information type according to the entity's data classification policy, and appropriately secure those sources according to the data's risk classification.

Management should develop design requirements and parameters for analytics. Data analytics results can be produced as dashboards and reports, which may be available on demand. Management and personnel using data analytics should have sufficient knowledge to interpret dashboards and reports. Insufficient dashboards or reports, or incomplete data, can lead to a misunderstanding or misuse of the data in decision-making processes. Management should consider the following when implementing and using data analytics:

- Document the types of data maintained, data owners and users, and purpose for reports.
- Determine usage needs by stakeholders (e.g., internal personnel and customers) and the ability of analytics reports to meet them.
- Determine whether there are opt-in considerations based on the information type in the analytics reports.
- Determine disclosure requirements (e.g., to regulatory agencies, internal stakeholders, and customers) in the event of a security incident.
- Implement access controls and activity monitoring over analytics tools and reports.
- Define processes to remove or destroy data when no longer used in the data analytics tools.

- Identify data that are subject to applicable laws and regulations (e.g., “Interagency Guidelines Establishing Information Security Standards” [Information Security Standards],¹⁸ the Fair Credit Reporting Act, and the Equal Credit Opportunity Act) or other relevant industry standards (e.g., PCI DSS).
- Identify data analytics processes used by the entity to comply with applicable laws and regulations (e.g., Bank Secrecy Act/anti-money laundering, the Office of Foreign Assets Control, or the Sarbanes–Oxley Act [SOX]).

According to the National Institute of Standards and Technology (NIST), the growth of data is outpacing the abilities of current data analytics systems to process the data.¹⁹ This exponential growth of data has produced larger and more varied pools of data, often referred to as big data,²⁰ which need to be analyzed more rapidly.

Big data can be mined for information and is notable for the volume of data (including large amounts of sensitive customer information), the speed at which the data is processed, the variation in data types, or the variability (e.g., the change to a data set’s data flow rate, format, or volume). Specialized tools and software have enabled complex and high-volume data analytics, especially for big data. Risks associated with big data include unintended uses of information or patterns (specifically with sensitive customer and entity information); concerns with the maintenance, use, and protection of sensitive customer and entity information; third-party access to data; and compliance risks. As part of its mitigation strategy, management should implement appropriate security policies, standards, and procedures, along with data access and security controls in accordance with the entity’s data classification policy. Refer to the *IT Handbook’s* “[Information Security](#)” booklet for more information.

¹⁸ Refer to 12 CFR 30, appendix B (OCC); 12 CFR 208, appendix D-2 and 225, appendix F (FRB); 12 CFR 364, appendix B (FDIC); and 12 CFR 748, appendix A (NCUA) (collectively referenced in this booklet as the Information Security Standards).

¹⁹ [NIST Big Data Interoperability Framework: Volume 1, Definitions.](#)

²⁰ [Ibid.](#)

III.B IT Asset Management

Action Summary

Management should have appropriate ITAM processes to track, manage, and report on the entity's information and technology assets.

Examiners should review for the following:

- Policies, standards, and procedures.
- Technology asset inventories.
 - Hardware inventory, including telecommunications.
 - Software inventory.
- Processes to address IT asset EOL.
- Processes to prevent and detect unknown or unapproved technology (called shadow IT).

ITAM is the process to track, manage, and report on information and technology assets²¹ throughout their entire life cycle. ITAM plays a significant role in the AIO functions, demonstrated by the following examples. In architecture, if management is aware of the entity's current inventories, it can determine the necessary design changes to meet strategic goals and objectives. For infrastructure, ITAM allows management to acquire hardware or software components that are interoperable with the entity's existing infrastructure. With respect to operations, the ITAM inventories help management know what systems need to be patched and the patch time frames, what hardware or software is nearing its EOL, where the entity's vulnerability management focus should be, or when any additional security measures are necessary.

Management should have a comprehensive inventory of its electronic (or digital) and physical information assets to adequately safeguard them against reasonably foreseeable threats. An inventory will assist management as it develops and maintains the entity's information security program as described in the Information Security Standards.²² As part of the entity's information and technology asset inventory, management should specifically identify the entity's information assets, determine the assets' appropriate classification, and protect the assets according to the

²¹ Information and technology assets can include hardware, software, mobile devices, virtual and cloud assets, physical assets (e.g., cabinets, locks, and hard copy information assets), digital information assets (e.g., data), and third-party managed assets.

²² Refer to 12 CFR 30, appendix B (OCC); 12 CFR 208, appendix D-2 and 225, appendix F (FRB); 12 CFR 364, appendix B (FDIC); and 12 CFR 748, appendix A (NCUA). Section III.C of the Information Security Standards requires each financial institution to have a comprehensive written information security program designed to manage and control risk where each institution shall design its information security program to control the identified risks, commensurate with the sensitivity of the information as well as the complexity and scope of the institution's activities. Each institution must consider whether the security measures set forth in III.C.1 are appropriate for the institution.

entity's data classification process. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information on methods for safeguarding sensitive customer information.

Management should implement policies, standards, and procedures to govern all aspects of ITAM, including information and technology assets. The ITAM process includes identifying the technology assets that the entity possesses and manages, determining each asset's status (e.g., active or inactive), and identifying the life cycle phase of those assets. Management should regularly review and validate the accuracy of the inventories. The ITAM process also includes identifying personally owned technology assets that are allowed to connect to the entity's network, with considerations such as the design, implementation, and controls over the assets' use. Management may use ITAM to help make informed, business-driven decisions for entity-owned and personally owned IT assets.

The inventories help management identify or understand the following aspects of ITAM:

- License utilization.
- Support costs related to maintenance, utilization, and obsolescence.
- Existence of unauthorized devices operating on the entity's networks.
- Potential vulnerabilities, such as hardware and software that are in need of upgrade or are reaching EOL.
- Compliance with internal configuration and security standards, as well as contractual requirements.
- Critical interdependencies (e.g., third-party service providers, software, hardware, and business units).

As part of ITAM, management should use appropriate inventory mechanisms to track and validate the entity's information and technology assets. Smaller or less complex entities may use informal methods (e.g., spreadsheets) to track IT assets. Larger or more complex entities may use more sophisticated methods or automated tools to assist with ITAM. Automated tools can provide a variety of functionality, such as logging and vital asset statistics. Some automated tools alert management when a new or unapproved device is connected to the entity's network. Because automated inventory methods or tools may not identify all IT assets that connect to the network, management may need to manually inventory those types of devices (e.g., internet of things [IoT] devices).

III.B.1 Technology Asset Inventory

Building technology asset inventories is a foundational process that management uses to identify entity-owned IT assets. The inventories should include information regarding the entity's hardware, software, and telecommunications. Management also should consider IT assets that do not fall into traditional hardware or software inventories, such as internet assets (e.g., website addresses owned, certificates employed, domains used, or rights to audio or video files). Smaller or less complex entities may have one comprehensive inventory that contains all of its technology assets. Larger or more complex entities may have multiple inventories to track their technology assets. Management can leverage the technology asset inventories for the following purposes:

- Supporting the entity's risk assessments (e.g., information security, SOX, continuity and resilience, or business unit).
- Evaluating the design of the infrastructure and IT environment supporting business processes.
- Identifying potential security weaknesses (e.g., assets reaching EOL or operating on outdated versions of software).
- Managing vulnerabilities by identifying necessary versions and patch levels for continuity of operations.
- Aligning with strategic planning (e.g., acquiring specific technology for current and future business needs).
- Assisting in audit risk assessments and building the audit universe and scope.

There are tools that may help management identify and manage hardware (including telecommunications) and software in the entity's IT environment. For example, automated asset management tools can scan an entity's IT environment for unauthorized hardware, software, and devices (sometimes called shadow IT). Smaller or less complex entities may use manual asset inventory processes; these processes, however, should allow management to effectively document, track, and oversee the entity's technology assets.

ITAM policies, standards, and procedures should outline a process to update the technology inventories after changes to IT infrastructure or operations. All inventories should be periodically reviewed to verify that they accurately capture the entity's technology assets.

III.B.1(a) *Hardware Inventory*

Management should maintain a hardware²³ inventory that identifies the entity's hardware assets. The hardware inventory should identify equipment owned and managed by third parties on the entity's behalf that may be located within the entity's environment (e.g., wire transfer routers, core processing hardware, and third-party security monitoring devices). The hardware inventory should include entity-owned and entity-managed virtual infrastructures (e.g., virtual servers on the entity's premises or virtual servers in a cloud environment). To the extent possible, hardware items should be assigned a unique identifier (e.g., labels or bar codes) to allow management to identify, account for, and monitor for changes to hardware assets.

The entity's hardware inventory should contain information about the entity's network and telecommunications equipment. The information includes the type, use, and configuration of the equipment and related software that provides internal and external network connections.

The following are examples of information to include in the hardware inventory:

- Vendor and model.
- OS version or release level.
- Function or use.

²³ For the purposes of this booklet, hardware includes devices, mainframes, servers, storage equipment, desktops, and printers.

- Status (e.g., active, nearing EOL, or decommissioned).
- Memory and storage size.
- Processor speed.
- Owner or contact information.
- Network connectivity.
- Physical location.
- Identifiers (e.g., internet protocol [IP] address and media access control [MAC] address).
- Criticality classification.
- Upstream and downstream connections.
- Environment (e.g., production, test, or development).
- Firmware version.
- Most recent maintenance date.
- EOL date, if applicable.
- Network and telecommunications equipment, including:
 - Routers.
 - Firewalls.
 - Intrusion detection and prevention systems (IDS/IPS).
 - Virtual private networks (VPN).
 - Telecommunication lines.
 - Provider.

In addition to hardware, additional information should be considered when evaluating the network (e.g., network segments and associated attributes, such as IP addresses, domains, network protocols, and third-party network contractual arrangements) and these can also tie to the entity's software inventory.

III.B.1(b) *Software Inventory*

Similar to a hardware inventory, management should maintain an accurate software inventory. The software inventory provides detailed information on software used within the entity's IT environment. The following are examples of information to include in the software inventory:

- Application or database name and type (e.g., general ledger or payroll).
- Developer (e.g., developer name or internally developed).
- Vendor name, if not the developer.
- Install date.
- License renewal date.
- EOL (e.g., end-of-support) date and expected software life, if applicable.
- Serial number.
- Version.
- Patch level.
- Last patch date.
- Number of copies, licenses, and users allowed, if applicable.
- Environment where software runs (e.g., production, test, or development).
- Owner or contact information.